

Digital Forensics Red, Blue and Purple Teaming Deception Technology



Security Operations & Incident response

- Email Analysis
- Phishing Email Analysis
- Email headers
- Malicious payloads
- Email Spoofing
- Embedded links



Labs

- Students will analyze the phishing email provided
- Students will investigate the provided URLs

Digital Forensics

- Digital Forensics is the discipline of **identifying, preserving, analyzing, and presenting digital evidence** in a manner that is legally admissible and technically sound.
- It plays a critical role in incident response, cybercrime investigations, regulatory compliance, and litigation support.
- Objectives of Digital Forensics
 - ✓ Determine what happened
 - ✓ Identify how the incident occurred
 - ✓ Establish who was involved
 - ✓ Assess scope and impact
 - ✓ Preserve evidence for legal or disciplinary action
 - ✓ Support root cause analysis and remediation



Digital Forensics Lifecycle

▪ Identification

- Detect potential sources of evidence
- Systems, logs, memory, network traffic

▪ Preservation

- Prevent evidence alteration
- Isolate systems
- Maintain chain of custody

▪ Collection

- Acquire data using forensically sound methods
- Bit-by-bit imaging
- Memory capture

▪ Examination

- Extract relevant artifacts
- Filter noise

▪ Analysis

- Correlate evidence
- Build timelines
- Attribute actions

▪ Presentation

- Document findings
- Prepare reports
- Support legal proceedings

Types of Digital Forensics

- **Computer (Host) Forensics**

- File systems
- Registry
- Installed applications
- User activity

- **Memory Forensics**

- Running processes
- Network connections
- Malware artifacts

- **Network Forensics**

- Packet captures
- Firewall, proxy, IDS logs
- Traffic analysis

- **Mobile Forensics**

- Call logs
- Messages
- App data

- **Cloud Forensics**

- Cloud logs
- Object storage analysis
- Identity and access trails

Common Forensic Artifacts

- Event logs
- Browser history
- Registry keys
- Prefetch files
- Email headers
- Network flows
- Malware samples

Forensic Tools

- **Host Forensics**

- EnCase
- FTK
- Autopsy

- **Memory Forensics**

- Volatility
- Rekall

- **Network Forensics**

- Wireshark
- Zeek
- NetworkMiner

- **Timeline Analysis**

- Plaso (log2timeline)

Chain of Custody

- A formal record documenting:
 - Who collected evidence
 - When and where
 - How it was stored
 - Every transfer or access
- This ensures evidence admissibility.

Red, Blue and Purple Teaming



RED TEAM

ATTACKERS

Works to break into the system.

Skills include:

- Penetration Testing
- Vulnerability Scanning
- Social Engineering
- Threat Intelligence
- Custom Toolset Development

PURPLE TEAM

MEMBERS FROM BOTH TEAMS

Gets blue and red teams to work together to improve an organisation's security posture.

Skills include:

- Collaboration
- Information-Sharing
- Reporting and Analysis



BLUE TEAM

DEFENDERS

Works to keep the systems safe.

Skills include:

- Network Monitoring
- Data and Log Analysis
- Risk Assessments
- Threat Detection



Red Team

- **Playing offense**, the red team attacks and attempts to break the blue team's defenses.
- The Red Team simulates real-world attackers to identify exploitable weaknesses across people, processes, and technology.
- Red teams usually consist of ethical hackers, penetration testers and other security professionals. To be effective, red team members should have no knowledge of an enterprise's defense mechanisms
- Objectives of Red Team:
 - Emulate advanced threat actors (APT, ransomware groups)
 - Test detection and response capabilities
 - Expose security gaps before attackers do



Red Team

Activities

- Phishing campaigns
- Exploitation of vulnerabilities
- Lateral movement
- Privilege escalation
- Command-and-control simulation
- Physical and social engineering (in some engagements)

Tools (Examples)

- Metasploit
- Cobalt Strike
- Bloodhound
- Burp Suite
- Nmap

Deliverables

- Attack paths
- Exploited vulnerabilities
- Impact assessment
- Recommendations

Blue Team

- Playing defense, the blue team is responsible for regularly analyzing enterprise systems to adequately protect them, identifying and remediating vulnerabilities, and evaluating the effectiveness of security tools and processes.
- The Blue Team is responsible for **defending, detecting, and responding** to cyber threats.
- Objectives
 - Detect malicious activity
 - Contain and eradicate threats
 - Protect assets and data
 - Improve resilience



Blue Team

Activities

- Monitoring SIEM/EDR alerts
- Incident response
- Threat hunting
- Log analysis
- Security hardening

Tools (Examples)

- SIEM (Splunk, QRadar)
- EDR/XDR (Defender, CrowdStrike)
- SOAR
- IDS/IPS
- Firewalls and WAFs

Deliverables

- Incident reports
- Detection rules
- Response playbooks
- Security improvements

Purple Team

- Calling the purple team a *team* is a bit misleading.
- The purple team is, in fact, not a standalone team but a mix of blue and red team members, roles and responsibilities.
- The Purple Team is not a separate team but a collaborative function that integrates Red and Blue teams to maximize defensive maturity.
- Objectives:
 - Translate attacks into detections
 - Improve visibility and response speed
 - Close security gaps faster



Purple Team

Activities

- Attack-to-detection mapping
- Joint exercises
- MITRE ATT&CK alignment
- Detection engineering
- Continuous validation

Tools (Examples)

- MITRE ATT&CK Navigator
- Atomic Red Team
- Caldera
- Detection-as-Code frameworks

Deliverables

- Improved detection coverage
- Refined response playbooks
- Measurable security metrics

Red vs Blue vs Purple

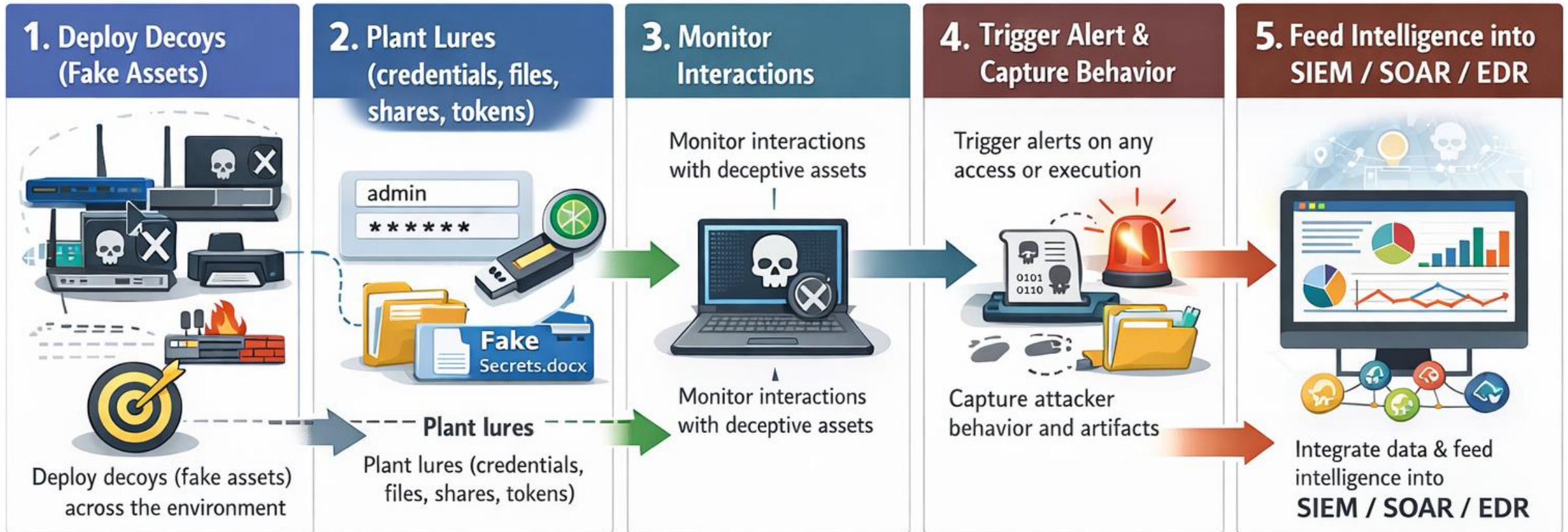
Aspect	Red Team	Blue Team	Purple Team
<i>Focus</i>	Attack	Defence	Collaboration
<i>Goal</i>	Find weaknesses	Stop attacks	Improve both
<i>Timeframe</i>	Periodic	Continuous	Continuous
<i>Outcome</i>	Findings	Incidents handled	Detection maturity

Deception Technology

- Deception Technology is a defensive cybersecurity approach that uses decoys, traps, and lures to deliberately mislead attackers, detect malicious activity early, and gather high-fidelity threat intelligence.
- Core Objectives of Deception Technology:
 - Detect attackers early in the kill chain
 - Identify lateral movement and privilege abuse
 - Generate high-confidence alerts (near-zero false positives)
 - Collect attacker TTPs for intelligence and response
 - Slow down and confuse adversaries



How Deception Technology Works?



Key Components of Deception Technology

Decoys

- Simulated assets that appear real:
 - Fake servers (Windows, Linux)
 - Databases
 - Domain controllers
 - Cloud workloads
 - Network devices

Lures

- Artifacts that attract attackers:
 - Fake credentials
 - Browser cookies
 - Configuration files
 - SSH keys
 - API tokens

Tokens

- Digital breadcrumbs used for detection:
 - Canary tokens
 - DNS tokens
 - SMB tokens
 - Cloud access keys

Email Analysis

- Email Analysis is the systematic examination of email messages to **identify phishing, malware, spam, business email compromise (BEC), and data exfiltration attempts.**
- It is a core function of **SOC operations, incident response, and digital forensics**, as email remains the primary initial access vector.
- Objectives of Email Analysis:
 - Determine whether an email is malicious or legitimate
 - Identify threat type (phishing, malware, BEC, spam)
 - Extract indicators of compromise (IOCs)
 - Assess impact and exposure
 - Support containment and remediation



Types of Malicious Emails

- Phishing
- Spear phishing
- Whaling
- Business Email Compromise (BEC)
- Malware delivery
- Spam and scam emails

Email Analysis Workflow

Step 1: Initial Triage

- User-reported or security alert
- Check sender, subject, urgency cues
- Determine risk level

Step 2: Header Analysis

- Identify sender authenticity
- Trace mail flow
- Detect spoofing

Step 3: Body and Content Analysis

- Social engineering techniques
- Malicious links or attachments
- Language anomalies

Step 4: URL Analysis

- Reputation check
- URL decoding
- Redirection analysis
- Sandbox testing

Step 5: Attachment Analysis

- File type verification
- Hash calculation
- Malware scanning
- Dynamic analysis

Step 6: Indicator Extraction

- IPs
- Domains
- URLs
- Hashes

Step 7: Impact Assessment

- Who received it
- Who clicked or executed
- Lateral spread risk

Step 8: Response Actions

- Block sender/domain
- Quarantine emails
- Reset credentials
- Awareness communication



Indicators of a Malicious Email

Technical Indicators

- SPF/DKIM/DMARC failures
- Mismatch between From and Return-Path
- Suspicious sending IP
- Shortened or obfuscated URLs

Behavioral Indicators

- Urgency or fear-based language
- Requests for credentials or payments
- Unexpected attachments
- Poor grammar (context-dependent)



Common Tools for Email Analysis

- **Header Analysis**

- Message Header Analyzer (Microsoft)
- Google Admin Toolbox

- **URL & Reputation**

- [VirusTotal](#)
- URLScan
- Threat intelligence platforms

- **Attachment Analysis**

- Sandbox solutions
- Antivirus engines
- Static file analysis tools

Phishing Email Analysis

- Phishing Email Analysis is the structured process of determining whether an email is attempting to **steal credentials, deliver malware, or conduct fraud**, and to assess its **scope, impact, and required response**.
- Objectives
 - Confirm whether the email is phishing
 - Identify attack technique (credential harvest, malware, BEC)
 - Extract Indicators of Compromise (IOCs)
 - Determine user exposure
 - Support containment and remediation



Phishing Analysis Workflow

1. Initial Triage
2. Collect Email Artifacts
3. Header Analysis
4. URL Analysis (Most Critical)
5. Attachment Analysis
6. Sender Infrastructure Validation
7. Content & Social Engineering Analysis
8. Endpoint Impact Check (If User Clicked)
9. Threat Intel Correlation
10. Classification & Response
11. Containment Actions
12. Documentation (IR Requirement)



Phishing Analysis Workflow - Initial Triage

- Objective:
 - ✓ Decide quickly if it's suspicious and needs deep analysis.
- Check:
 - ✓ Sender display name vs actual email address
 - ✓ Urgency language (“account locked”, “payment failed”)
 - ✓ Unexpected attachments or links
 - ✓ Spoofed internal users (CEO, HR, IT)



Phishing Analysis Workflow - Collect Email Artifacts

- Objective:
 - ✓ Work with the original message, not a screenshot.
- Export:
 - ✓ Full email (.eml or .msg)
 - ✓ Headers
 - ✓ Attachments
 - ✓ Embedded links/URLs
- These are critical for forensic validation.



Phishing Analysis Workflow - Header Analysis

- Objective:
 - ✓ Headers reveal the real sending path.
- Focus fields:
 - ✓ From
 - ✓ Reply-To
 - ✓ Return-Path
 - ✓ Received chain
 - ✓ SPF result
 - ✓ DKIM signature
 - ✓ DMARC alignment
- Look for:
 - ✓ Domain mismatch (display vs actual sender)
 - ✓ Failed SPF/DKIM/DMARC
 - ✓ Suspicious relay servers
 - ✓ External origin posing as internal



Phishing Analysis Workflow - URL Analysis (Most Critical)

- Objective:

- ✓ ***Never click directly.***

- Check:

- ✓ Domain spelling (paypal vs paypal)

- ✓ URL shorteners

- ✓ Newly registered domains

- ✓ HTTP vs HTTPS

- ✓ Hidden hyperlink text mismatch.

- Use:

- ✓ sandbox detonation

- ✓ URL reputation tools

- ✓ WHOIS lookup

- Red flags:

- ✓ Credential harvesting pages

- ✓ Fake login portals

- ✓ Redirect chains

Phishing Analysis Workflow - Sender Infrastructure Validation

- Objective:
 - ✓ Investigate sender domain.
- Check:
 - ✓ Domain age
 - ✓ DNS records
 - ✓ MX records
 - ✓ IP reputation
 - ✓ Hosting provider
- New domains (<30 days) are common in phishing campaigns.



Phishing Analysis Workflow - Content & Social Engineering Analysis

- Assess psychological triggers:
 - Authority impersonation (bank, IT, CEO)
 - Fear/urgency
 - Payment requests
 - MFA reset prompts
 - Invoice scams



Phishing Analysis Workflow - Endpoint Impact Check (If User Clicked)

- Investigate host:
 - browser history
 - downloads
 - process execution
 - PowerShell logs
 - EDR alerts
 - credential login attempts
- Windows artifacts:
 - Event ID 4688 (process)
 - Event ID 4624 (logon)
 - browser cache



Phishing Analysis Workflow - Threat Intel Correlation

- Search indicators:
 - sender email
 - domain
 - URL
 - file hash
 - IP address
- Check against:
 - threat feeds
 - SIEM logs
 - EDR telemetry
- Determine:
 - isolated email
 - targeted attack
 - organization-wide campaign



Phishing Analysis Workflow - Classification & Response

Scenario	Action
Suspicious only	Monitor
Phishing attempt	Block sender/domain
User clicked link	Reset credentials
Malware attachment	Isolate endpoint
Org-wide campaign	Security advisory

Phishing Analysis Workflow - Containment Actions

- SOC actions typically include:
 - Block domain/IP at firewall
 - Add IOC to SIEM
 - Remove email from mailboxes
 - Disable compromised accounts
 - Force password reset
 - Enable conditional access/MFA



Phishing Analysis Workflow - Documentation (IR Requirement)

- Record:
 - timeline
 - indicators
 - impacted users
 - response actions
 - lessons learned
- Feeds future detection engineering.

Common Phishing Techniques

- Brand impersonation
- Invoice fraud
- MFA fatigue phishing
- OAuth phishing
- QR code phishing
- CEO fraud (BEC)



Email headers

- Email headers are **hidden metadata** added by mail servers as a message travels from sender to recipient.
- They reveal:
 - ✓ Where the email originated
 - ✓ Which servers handled it
 - ✓ Whether the sender is authenticated
 - ✓ If the message was altered

Message headers

```
X-Pm-Content-Encryption: end-to-end
X-Pm-Origin: internal
Subject: Seattle trip
To: Kristen Novak <kristennovak@proton.me>
From: Eric Norbert <eric.norbert@proton.me>
Date: Tue, 14 Mar 2023 16:29:46 +0000
Mime-Version: 1.0
Content-Type: text/html
Message-Id:
<hvl1FNSqLpe7Va0W4vl8oXzhimc9lBJQLK0jSg0zJtRzWZkzfohHSH0h5yTrIXn_pQ76eZMB7EzXQG
R3Q15LGKQGec9ZNdSuLgp1rj6TUXI=@proton.me>
X-Pm-Spamscore: 0
Received: from mail.protonmail.ch by mail.protonmail.ch; Tue, 14 Mar 2023
16:29:53 +0000
X-Original-To: kristennovak@proton.me
Return-Path: <eric.norbert@proton.me>
Delivered-To: kristennovak@proton.me
```



Importance of Email Header in Security

- Detect spoofed or impersonated emails
- Validate sender authenticity
- Identify phishing infrastructure
- Trace attacker origin
- Support legal and forensic investigations

Key Email Header Fields

- From - Displayed sender name and address
- Return-Path - Often reveals true sending domain
- Received - Shows each mail server hop
- Message-ID - Unique identifier
- Reply-To - Where replies are sent

Tools for Email Header Analysis

- Microsoft Message Header Analyzer
- Google Admin Toolbox
- MXToolbox
- SIEM platforms



Malicious payloads

- A malicious payload is the harmful component of an attack that executes the **attacker's intended action** after successful delivery or exploitation.
- It is the stage where **actual damage, control, or data theft** occurs.
- The payload is responsible for **execution and post-exploitation behavior**.
- Malicious Payloads in the Attack Lifecycle:

1. Reconnaissance

2. Weaponization (payload creation)

3. Delivery

4. Exploitation

5. Installation / Execution (Payload runs)

6. Command and Control

7. Actions on Objectives

Common Types of Malicious Payloads

- **Malware Payloads**

- Ransomware – Encrypts data for extortion
- Trojans – Disguised as legitimate software
- Worms – Self-propagating
- Spyware – Steals sensitive information
- Keyloggers – Captures keystrokes

- **Backdoor Payloads**

- Provide persistent remote access
- Bypass authentication
- Often used by APT actors

- **Exploit Payloads**

- Execute code after exploiting a vulnerability
- Often delivered via browser, document, or service exploit

- **Downloader / Dropper Payloads**

- Initial lightweight payload
- Downloads additional malware stages
- Used to evade detection

- **Credential Theft Payloads**

- Browser credential stealers
- LSASS memory dumpers
- Token and cookie stealers

- **Fileless Payloads**

- Execute in memory
- Use PowerShell, WMI, or LOLBins
- Leave minimal disk artifacts

Common Payload Delivery Methods

- Phishing email attachments
- Malicious URLs
- Drive-by downloads
- USB devices
- Exploited services (RDP, VPN)
- Supply chain compromise

Payload Formats

- Executables (.exe, .dll)
- Scripts (.ps1, .vbs, .js)
- Office documents with macros
- PDFs
- HTML smuggling files
- ISO, ZIP, LNK containers

Indicators of Malicious Payloads

- **File-Based Indicators**

- Unexpected file execution
- Obfuscated or packed binaries
- Suspicious file names and locations
- Hash reputation matches

- **Behavioral Indicators**

- Process injection
- Registry persistence
- Unauthorized network connections
- Credential access attempts

Email Spoofing

- Email spoofing is a technique where attackers forge the sender address or email headers to make a message appear as if it originated from a trusted individual, organization, or internal domain.
- It is a foundational tactic used in **phishing, BEC, and malware delivery attacks**.
- Attackers manipulate email components so the message appears legitimate:
 - Fake From address (display name spoofing)
 - Forged Return-Path
 - Abuse of misconfigured mail servers
 - Exploiting lack of email authentication (SPF/DKIM/DMARC)



Common Email Spoofing Techniques

- Display Name Spoofing - Sender name looks legitimate
 - From: **IT Support** <alerts@gmail.com>
- Domain Spoofing - Fake domain similar to a trusted one
 - **support@micr0soft.com**
- Direct Domain Spoofing - Attacker sends email claiming to be from your domain
 - **ceo@yourcompany.com** (sent externally)
- Reply-To Spoofing - Replies redirected to attacker-controlled inbox
- Lookalike / Homograph Domains - Unicode characters visually similar to real domains

How to Detect Email Spoofing

- **Manual Analysis**

- Review full email headers
- Validate SPF/DKIM/DMARC results
- Inspect Received chain

- **Automated Detection**

- Secure Email Gateways (SEG)
- AI-based email security tools
- DMARC monitoring services

Embedded links

- Embedded links are hyperlinks placed within the body of an email, document, or web page that redirect users to external or internal destinations.
- In cybersecurity, embedded links are a primary delivery mechanism for phishing, malware, credential harvesting, and redirection attacks.
- Attackers rely on embedded links because:
 - They exploit **human trust and urgency**
 - The visible text can differ from the actual URL
 - They enable **credential theft without malware**
 - They bypass traditional attachment-based defenses



Types of Malicious Embedded Links

- **URL Mismatch** - Visible text appears legitimate; actual URL is malicious.
 - Ex: `https://login.microsoft.com` → `https://micros0ft-login[.]com`
- **Lookalike / Typosquatting Domains**
 - Similar spelling or Unicode characters
- **Shortened URLs**
 - Hide final destination
- **Redirect Chains**
 - Multiple redirects to evade detection
- **Credential Harvesting Links**
 - Fake login portals
 - Capture usernames, passwords, MFA tokens



Indicators of Malicious Embedded Links

Technical Indicators

- Newly registered domains
- IP-based URLs
- Non-standard TLDs
- HTTPS without valid trust context

Behavioral Indicators

- Urgent language (“Verify now”, “Account suspended”)
- Unexpected request
- Requests for credentials or payments

How to Analyze Embedded Links Safely

- Do not click the link
- Hover to inspect actual URL
- Copy link text without opening
- Decode URL encoding
- Check domain age and reputation
- Analyze redirect chain
- Open in a secure sandbox (if required)

Detection & Prevention Controls

▪ **Email Security**

- URL rewriting and time-of-click analysis
- Domain impersonation detection
- QR code inspection

▪ **Endpoint & Network**

- DNS filtering
- Secure web gateways
- Browser isolation

▪ **User Awareness**

- Verify links before clicking
- Bookmark trusted portals
- Report suspicious emails

Embedded Links vs Attachments

Aspect	Embedded Links	Attachments
<i>Risk Type</i>	Credential theft	Malware
<i>User Action</i>	Click	Open
<i>Detection</i>	Reputation-based	Static/Dynamic
<i>Persistence</i>	Low	High





That's all Folks!